



FLAGIT

FLAGIT

HSE Observation Platform
Security, Data Storage & Privacy Statement

Version 3.0 | April 2026 | getflagit.com

CONFIDENTIAL

Table of Contents

1. About FLAGIT	3
2. Where Is Your Data Stored?	3
3. Security Architecture	4
4. Data Privacy	5
5. AI Features	6
6. NCR Document Generation	6
7. Infrastructure & Hosting	7
8. Compliance & Standards	7
9. Incident Response	8
10. Availability & Uptime	8
11. Contact & Data Requests	8
12. Summary for Decision Makers	8



1. About FLAGIT

FLAGIT is a cloud-based HSE (Health, Safety & Environment) observation and compliance tracking platform designed for field officers, HSE managers, and site supervisors operating in construction, oil & gas, manufacturing, and industrial environments.

FLAGIT enables real-time observation reporting, corrective action tracking, NCR generation, photo evidence capture, and team collaboration — accessible from any device, anywhere on site.

2. Where Is Your Data Stored?

Cloud Infrastructure

All FLAGIT data is stored on Supabase, a world-class enterprise database platform built on PostgreSQL — the same database technology trusted by organisations including Apple, Instagram, and the International Space Station.

Data Centres

- Supabase operates on Amazon Web Services (AWS) infrastructure
- Data is hosted in highly available, redundant data centres
- Default region: US East (Virginia) — regional options available on request
- Data is replicated across multiple availability zones ensuring zero single point of failure

Backups

- Automatic daily backups are performed and retained for a minimum of 7 days
- Point-in-time recovery is available — data can be restored to any specific moment
- Backups are stored in geographically separate locations from primary data
- No data is ever permanently lost due to hardware failure

File Storage (Photos & Documents)

- Observation and close-out photos are stored in Supabase Storage
- All files are stored in private, access-controlled buckets
- Photos are only accessible to authenticated members of the relevant project
- Files are encrypted at rest and in transit
- Generated NCR PDF documents are produced client-side and are never stored on FLAGIT servers

3. Security Architecture

Authentication

- FLAGIT uses email-based One-Time Password (OTP) authentication
- No passwords are stored — eliminating password breach risks entirely
- Every login requires a fresh 6-digit code sent to the user's verified email
- Sessions are managed with industry-standard JWT (JSON Web Tokens) with automatic refresh and expiry

Invite-Only Access

- FLAGIT operates an invite-only access model
- No user can self-register and access project data without explicit approval from a project administrator
- Each invite is tied to a specific email address and project

- Invites expire and can be revoked instantly by administrators

Role-Based Access Control (RBAC)

FLAGIT enforces strict role-based permissions at every level:

Role	Capabilities
Admin	Full access — create, edit, delete observations, manage team members, send invites, revoke access, generate NCR documents
Member	Create and edit own observations, add comments, update status, view all project observations, generate NCR documents

Row-Level Security (RLS)

- Every database table is protected by Supabase Row-Level Security policies
- These policies are enforced at the database level — not just the application level
- Even if the application code were compromised, the database would still enforce access rules
- No user can ever access data from another organisation's project

Data Isolation

- Each organisation's data is completely isolated at the database level
- Project A cannot see, access, or query any data belonging to Project B
- This isolation is enforced by cryptographic user identity (UUID) — not just application logic

Encryption

- All data in transit is encrypted using TLS 1.2 / TLS 1.3 (HTTPS)
- All data at rest is encrypted using AES-256 encryption
- SSL certificates are issued and automatically renewed by Let's Encrypt
- The FLAGIT domain (getflagit.com) enforces HTTPS-only access — HTTP connections are automatically redirected

Infrastructure Security

- FLAGIT is primarily hosted on Vercel — a SOC 2 Type II certified global edge platform
- Netlify serves as a fully configured standby hosting platform providing redundancy and business continuity
- Both platforms operate global edge networks with DDoS protection built in
- No direct database access is exposed to the public internet
- All API keys and credentials are stored as server-side environment variables — never in source code or the browser

4. Data Privacy

What Data We Collect

FLAGIT collects only the minimum data necessary to operate the platform:

- **Account data:** Full name, email address, job role
- **Observation data:** Category, location, description, photos, timestamps, recommendations
- **Activity data:** Login timestamps, observation status updates, comments
- **Presence data:** Online/offline status (stored temporarily, not used for tracking)

What We Do NOT Collect

- No payment card information
- No biometric data
- No location/GPS tracking
- No device identifiers beyond what the browser provides
- No data is sold or shared with third parties for advertising purposes

Data Ownership

- Your organisation owns your data — at all times
- FLAGIT does not claim ownership of any observation data, photos, or reports generated on the platform
- Data export is available on request

Data Retention

- Active project data is retained for the duration of the subscription
- Upon account closure, data is retained for 30 days before permanent deletion
- Users may request immediate deletion of their data at any time

GDPR Compliance

FLAGIT is designed with GDPR principles in mind:

- **Lawful basis:** Data is processed only to deliver the contracted service
- **Data minimisation:** Only necessary data is collected
- **Right to access:** Users can request a copy of their data at any time
- **Right to erasure:** Users can request deletion of their personal data
- **Data portability:** Observation data can be exported in standard formats

5. AI Features

FLAGIT includes an optional AI-powered recommendation feature (Ask FLAGIT AI) that suggests corrective actions based on observation details.

- **AI suggestions are powered by** Google Gemini 2.5 Flash via a secure server-side function
- Observation data is sent securely to a server-side API function — the AI API key is never exposed to the browser or end users
- No observation data is stored or used for AI training by the AI provider
- AI queries are stateless — each request is independent with no memory of previous queries
- Use of the AI feature is optional — all fields can be completed manually

The server-side architecture ensures that AI credentials are held exclusively on FLAGIT's secure infrastructure, providing a significantly stronger security posture than client-side key storage.

6. NCR Document Generation

FLAGIT includes a built-in Non-Conformance Report (NCR) document generation feature that produces professional, print-ready PDF documents directly from observation data.

How It Works

- When an observation is raised with the NCR flag ticked, a Generate NCR Document button becomes available on the observation detail page

- Clicking the button instantly generates a professionally formatted A4 PDF document
- The NCR document includes all relevant observation data, corrective action requirements, photo evidence, signature fields, and a unique auto-generated NCR reference number
- Documents are generated client-side using the jsPDF library — no data is transmitted to external servers during generation
- The generated PDF can be downloaded, printed, emailed, or shared directly with the responsible person or organisation

NCR Document Contents

- Auto-generated NCR reference number and date
- Project and organisation details
- Location, category, and severity of non-conformance
- Full description of the non-conformance with photo evidence
- Required corrective action and close-out timeframe
- Reporter and responsible person details with signature fields
- Close-out status and verification section

NCR documents are branded with the FLAGIT identity and marked CONFIDENTIAL. They are suitable for formal submission to contractors, clients, and regulatory bodies.

7. Infrastructure & Hosting

FLAGIT operates a dual-platform hosting architecture designed for maximum reliability and business continuity:

Platform	Role	Status
Vercel	Primary production hosting — global edge network, automatic SSL, instant deployments	Active
Netlify	Standby redundancy platform — fully configured and ready for immediate activation	Standby
Supabase / AWS	Database, authentication, and file storage — always active regardless of hosting platform	Active

The dual-hosting architecture means that in the event of any issues with the primary platform, FLAGIT can be restored to full operation within minutes by activating the standby platform. DNS switchover is the only step required, keeping downtime to an absolute minimum.

8. Compliance & Standards

FLAGIT's infrastructure providers maintain the following certifications:

Provider	Certifications
Supabase / AWS	SOC 2 Type II, ISO 27001, ISO 27017, ISO 27018, GDPR compliant
Vercel (Primary)	SOC 2 Type II, GDPR compliant
Netlify (Standby)	SOC 2 Type II, GDPR compliant
Google (AI)	SOC 2 Type II, ISO 27001, GDPR compliant

9. Incident Response

In the event of a security incident:

- Affected organisations will be notified within 72 hours of discovery
- A full incident report will be provided including scope, impact, and remediation steps
- FLAGIT maintains an incident response plan aligned with ISO 27035 guidelines
- The standby hosting platform can be activated immediately to restore service if the primary platform is affected

10. Availability & Uptime

- FLAGIT targets 99.9% uptime for all production services
- Dual-platform hosting architecture provides additional resilience beyond standard uptime guarantees
- Real-time status monitoring is in place for all critical components
- Supabase maintains a published status page at status.supabase.com
- Vercel maintains a published status page at www.vercel-status.com
- Netlify maintains a published status page at www.netlifystatus.com

11. Contact & Data Requests

For any security concerns, data access requests, or privacy enquiries:

FLAGIT Support

support@getflagit.com
getflagit.com

Data requests are acknowledged within 48 hours and fulfilled within 30 days.

12. Summary for Decision Makers

Concern	FLAGIT Answer
Where is data stored?	AWS-backed Supabase cloud — enterprise grade
Is data backed up?	Yes — daily automatic backups with point-in-time recovery
Who can access our data?	Only invited members of your project — enforced at database level
Can other companies see our data?	No — complete cryptographic isolation between organisations
Is data encrypted?	Yes — AES-256 at rest, TLS 1.3 in transit
Is it GDPR compliant?	Yes — designed with GDPR principles
How is AI handled securely?	Via a server-side function — API keys never reach the browser
Can we generate NCR documents?	Yes — professional PDF NCRs generated instantly from any flagged observation

Concern	FLAGIT Answer
What if the hosting platform goes down?	Standby platform (Netlify) activates within minutes — no data loss
What if there's a breach?	72-hour notification, full incident report
Do you sell our data?	Never
Who owns the data?	Your organisation — always

This document was prepared by FLAGIT and is accurate as of April 2026. For the most current version please visit getflagit.com or contact support@getflagit.com

